HSLU Lucerne University of Applied Sciences and Arts

Architecture & Design

In a cyber security product context

Chris Ditze-Stephan



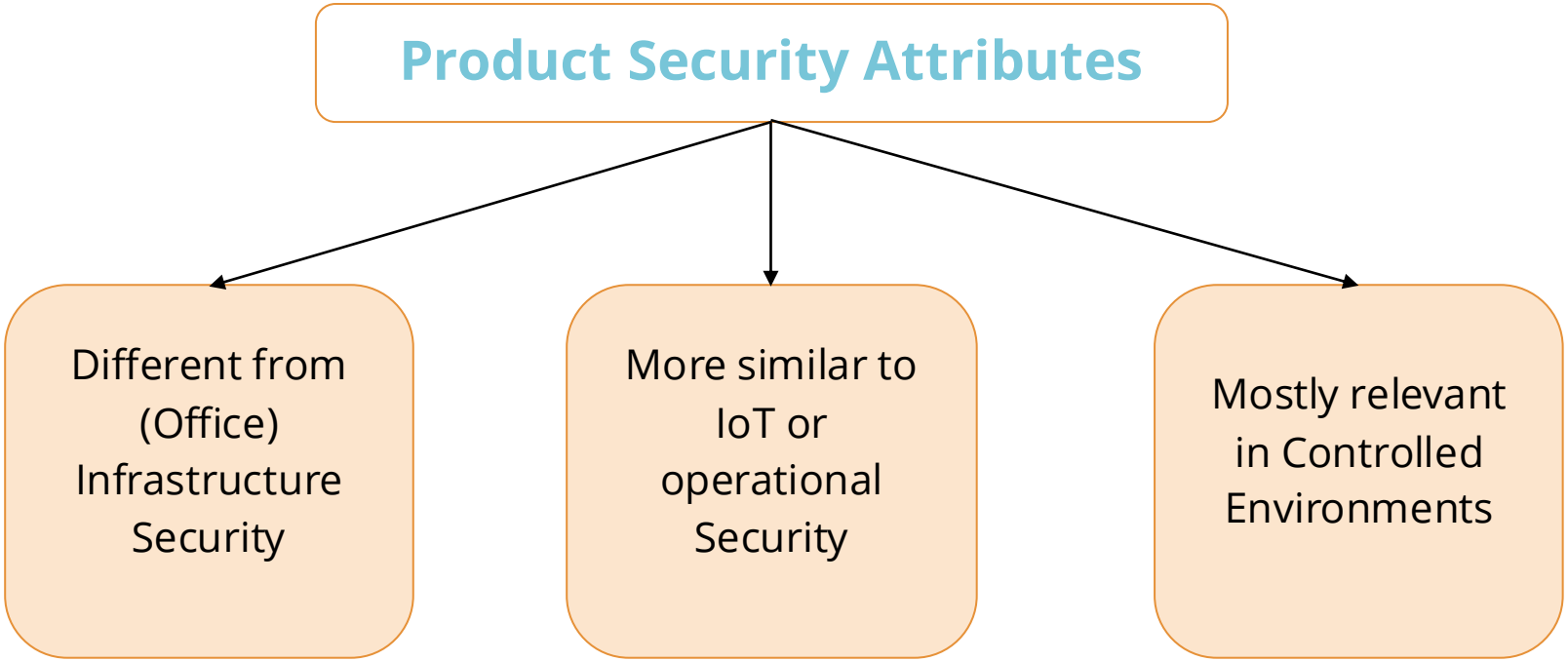
Information Technology
October 18, 2026

Session Goals

- The student understands what a Cybersecurity Product Architecture means and how we design it.
- The students know the main topics of most usage standards.
- The students are enabled to enrich a given Software/System architecture by Security elements and subsystems.

What is a Cybersecurity Product Architecture?

- Which attributes such a architecture should have?
- Which attributes such a architecture shouldn’t have?
- What happens if we wouldn’t have such a architecture?


Product Security Attributes
Different from (Office) Infrastructure Security
More similar to IoT or operational Security
Mostly relevant in Controlled Environments

Products









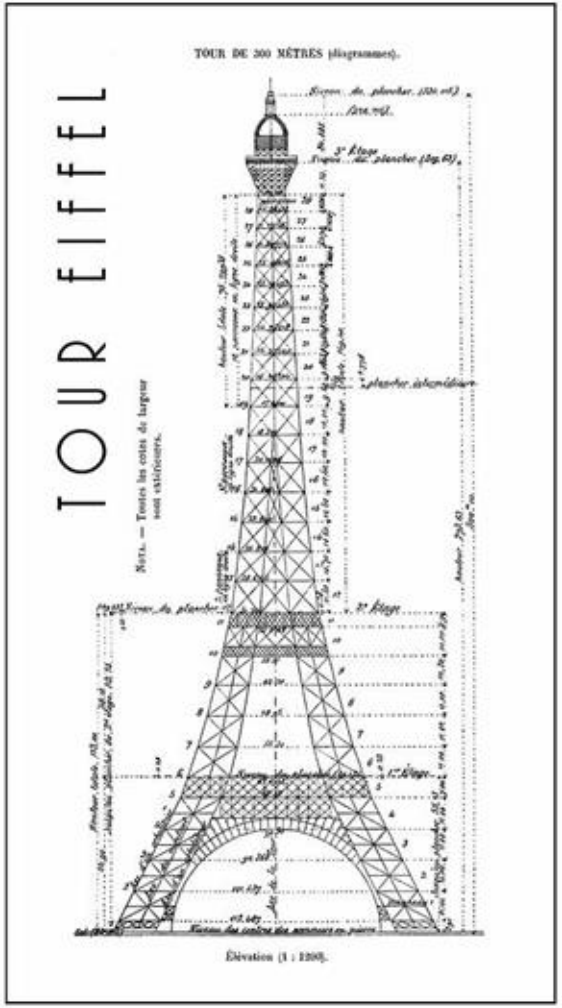
The way to understand it

related standards can be:

- ISO IEC 62443 (several documents)
  - 2-4 Security program requirements for IACS service providers
  - 3-2 Security risk assessment and system design (Draft)
  - 3-3 System security requirements and security levels
  - 4-1 Secure product development lifecycle requirements
  - 4-2 Technical security requirements for IACS components
- ISO IEC 27033-1 Network security Overview and concepts
- ISO IEC 27033-2 Guidelines for the design and implementation of network security
- ISO IEC 27033-3 Threats, design techniques and control issues
- ISO 27701 Extension to ISO IEC 27001 and ISO IEC 27002 for privacy information management, Requirements and guidelines

What means Architecture?

It could be useful if we understand in the beginning what means the common word architecture. The first association is mostly to imagine the building or blueprint of the building. And if you read the blueprint you can see doors and windows and possibly stairs.



If possible: "Form ever follows function." – ***Louis Sullivan***

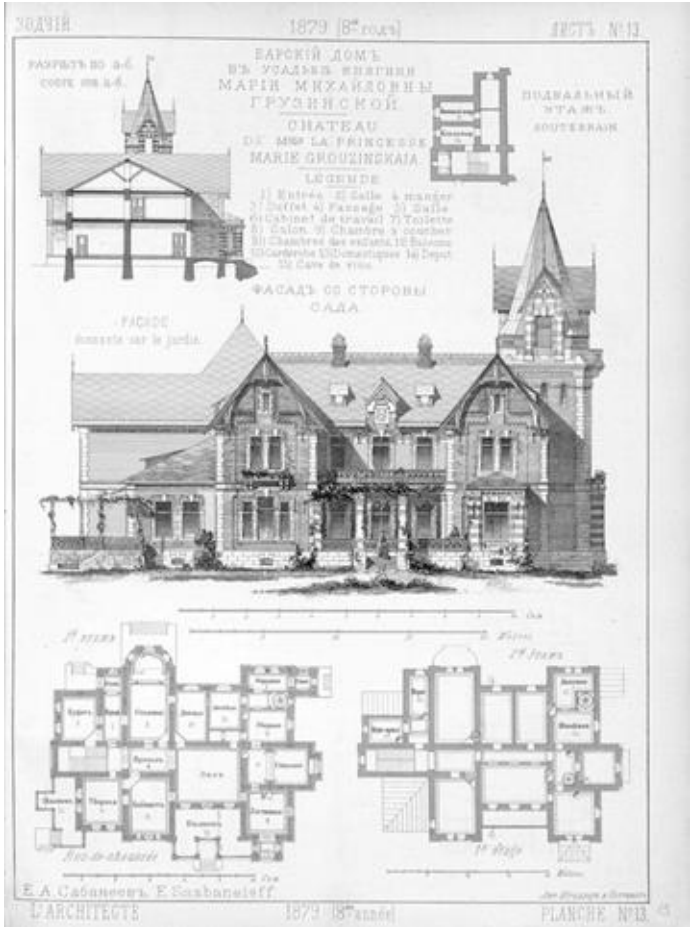
What means Architecture?

You are able to identify walls, floors, doors and windows.

And you can see the size of the building noted by numbers the height of the building by numbers.

It is recognizable that someone thinks about it.

"Not many architects have the luxury to reject significant things." – ***Rem Koolhaas***



What is a security architecture?

Security Architecture isn’t an appropriate wording but it is acceptable to use that.

Companies recruiting - from time to time - Security Architects. The consequence: Security Architectures existing!

What it means is: We need someone who will implement security elements and features to mitigate and control our cybersecurity threat-based risks!

And sometimes we have the challenge to occurs an IT Architecture which regard security interests.



What is a security architecture?

For better understanding the security architecture of the system, it will be helpful to understand what we miss if we haven’t any security architecture elements.

To talk about security architecture seems that there’s it is completely separated from all the other architectures. **But this is wrong!**



What is a security architecture?

ecurity features are always implemented or
esidewor between regular architectured
ements.

nd yeah we are a game, we talk about system
r multiple systems which are separated or
onnected.

need some rules like:
A trustworthy communication is only possible in a trustworthy environment!"

or

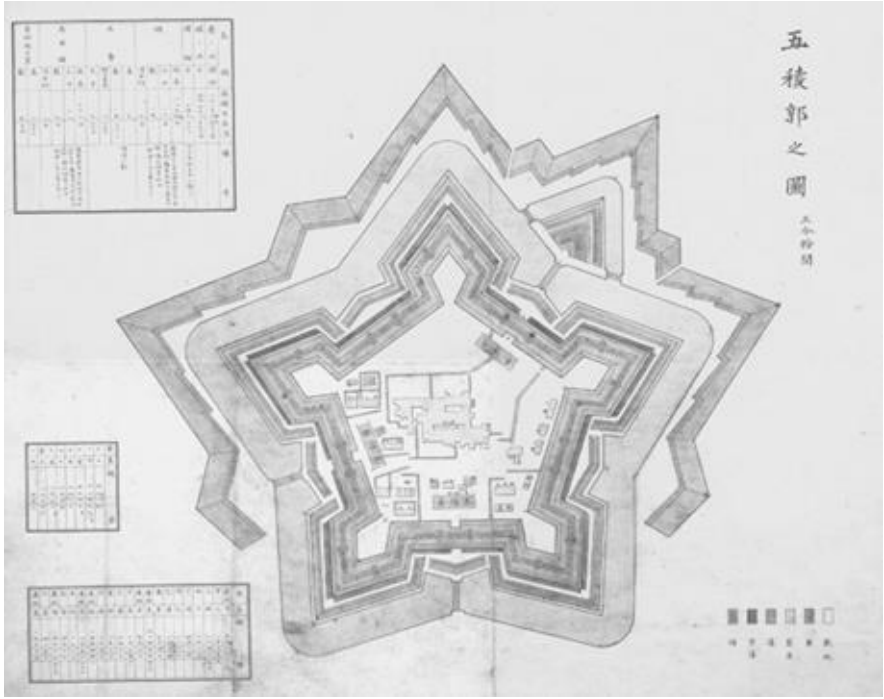
Complexity decreased security!" to design an
ppropriate cybersecurity architecture add-on-
et.



What is a security architecture?

Any intrusion detection system is completely senseless if I mounted different system then the system I like to protect, and indeed the story of security architecture‘s history of security confidence in the relations between the companies and do all the other elements of architecture.

What is the difference to Product Security Architectures and architecture Elements?



GOAL

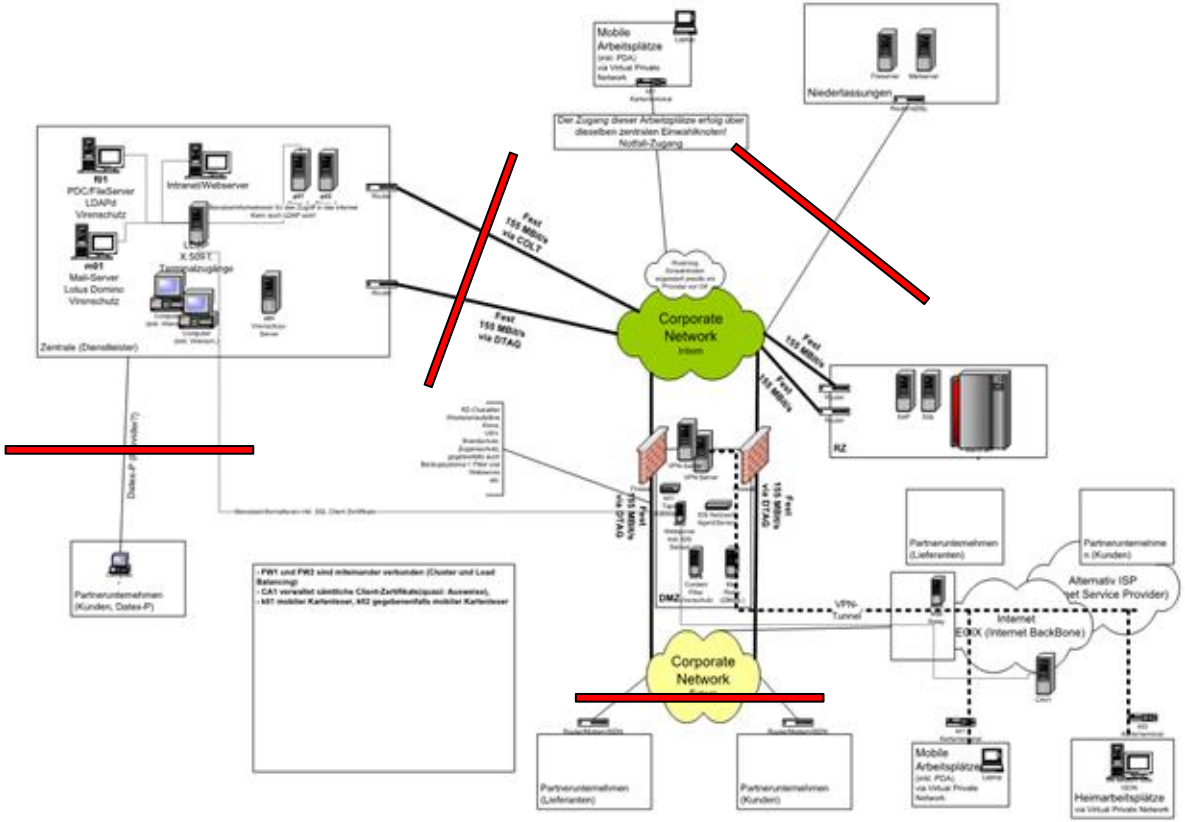
Build security architecture and verify the completeness - and correctness



DO´S

1. start with a clearly defined vision & mission statement
2. build a solid plan
3. socialize with leadership and obtain support
4. build an architectural charter
5. innovation and quick prototyping
6. SDLC process integration
7. **building awareness**
8. metrics and data-driven decision-making

Corporate network structure/architecture



Cybersecurity Design Patterns

*"Recognizing the need is the primary condition for design." – **Charles Eames***

In the past lectures we learned a lot about **REQUIREMENTS, RISKS, RISK MITIGATION** and **RISK CONTROL**.

But the programmer and the system engineer needs a specification. „What I have to do concrete now?"

What exactly he has to do to complete and be compliant to the organisation requirements?

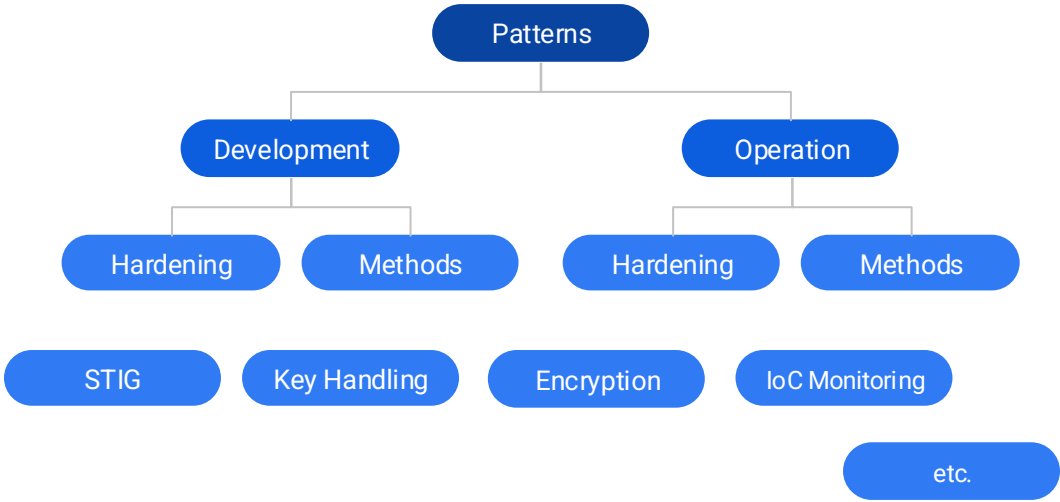
Protect the system is generic. Encrypt data is generic too. What sort of protection is enough? What sort of encryption is enough? Who decides what is finally enough or better sufficient?

There are agreed pattern or common design decisions which supports the engineer to do his work!

What is a design pattern?

Design patterns are used to represent some of the best practices adapted by experienced object-oriented developers.

A design pattern systematically names, motivates, and explains a general design that addresses a recurring design problem in object-oriented systems. It describes the problem, the solution, when to apply the solution and its consequences. It also gives implementation hints and examples.



Cybersecurity Design Patterns

Why so few organisations use such patterns?
(Other names than pattern are possible)

First: It needs a lot of effort to create them.

Second: It needs a lot of knowledge to decide about them.

Third: The most cybersecurity staff learn high-level security but no technical facts.

Design Topics

- (FR 1) Identification/Authentication/Access Control
- (FR 2) Use Control - Authorization
- (FR 3) System Integrity
- (FR 4) Data Confidentiality - Encryption
- (FR 5) Restricted Data Flow - Firewalling & Segregation
- (FR 6) Response (Timely) - Issue/Incident Handling/Response
- (FR 7) Resource Availability - Clustering/Monitoring

Based on IEC 62443-4-2

IEC 62443-4-2

Within the IEC 62443 standard are several **subsections** that relate to different parties. The IEC 62443-4-2 subsection issues guidelines for component suppliers. The component requirements are derived from foundational requirements, including identification and authentication control, use control, data integrity and confidentiality, as well as a backup for resource availability.



GOAL

Resolve the requirements



DO´S

Design Elements:

- PKI
- Firewall
- Intrusion Detection
- Intrusion Prevention
- Malware Protection (white/blackl
- Audit Logging (central loghosts)
- Patch Infrastructure
- etc.

6.3.3 Requirement enhancements

6.3.3.1 SR 2.1 RE 1 – Authorization enforcement for all users

On all interfaces, the control system shall provide the capability to enforce authorizatio assigned to all users (humans, software processes and devices) for controlling use of t control system to support segregation of duties and least privilege.

6.3.3.2 SR 2.1 RE 2 – Permission mapping to roles

The control system shall provide the capability for an authorized user or role to define a modify the mapping of permissions to roles for all human users.

NOTE 1 It is a commonly accepted good practice to not limit roles to fixed nested hierarchies in which a hig level role is a superset of a lesser privileged role. For example, a system administrator generally does necessarily encompass operator privileges.

NOTE 2 This RE is applicable to software processes and devices as well.

6.3.3.3 SR 2.1 RE 3 – Supervisor override

The control system shall support supervisor manual override of the current human us authorizations for a configurable time or event sequence.

NOTE Implementation of a controlled, audited and manual override of automated mechanisms in the event emergencies or other serious events is often needed. This allows a supervisor to enable an operator to quic react to unusual conditions without closing the current session and establishing a new session as a higher privile human user.

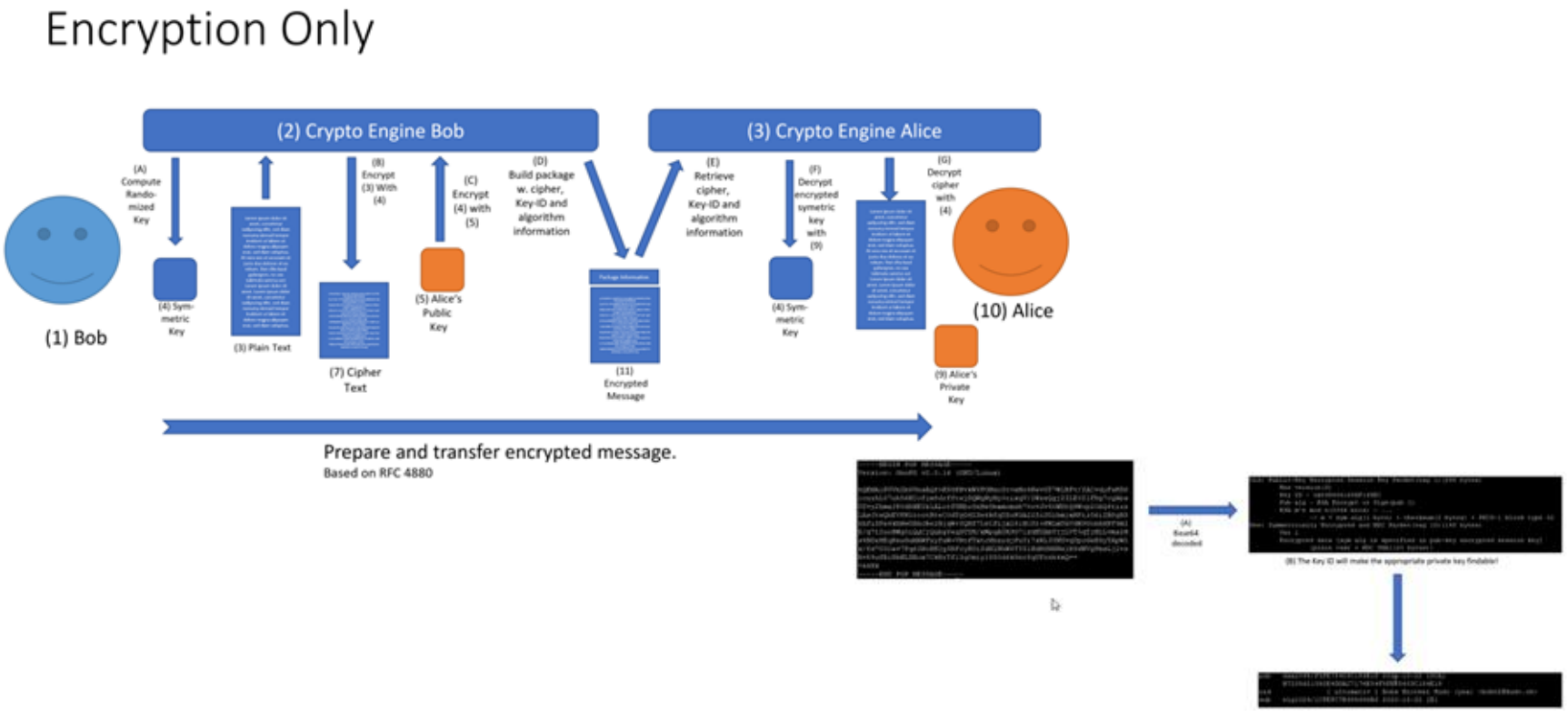
PKI

Public Key Infrastructure (PKI) is a technology for authenticating users and devices in the digital world. The basic idea is to have one or more trusted parties digitally sign documents certifying that a particular cryptographic key belongs to a particular user or device. The key can then be used as an identity for the user in digital networks.

Most public key infrastructures use a standardized machine-readable certificate format for the certificate documents. The standard is called X.509v3.



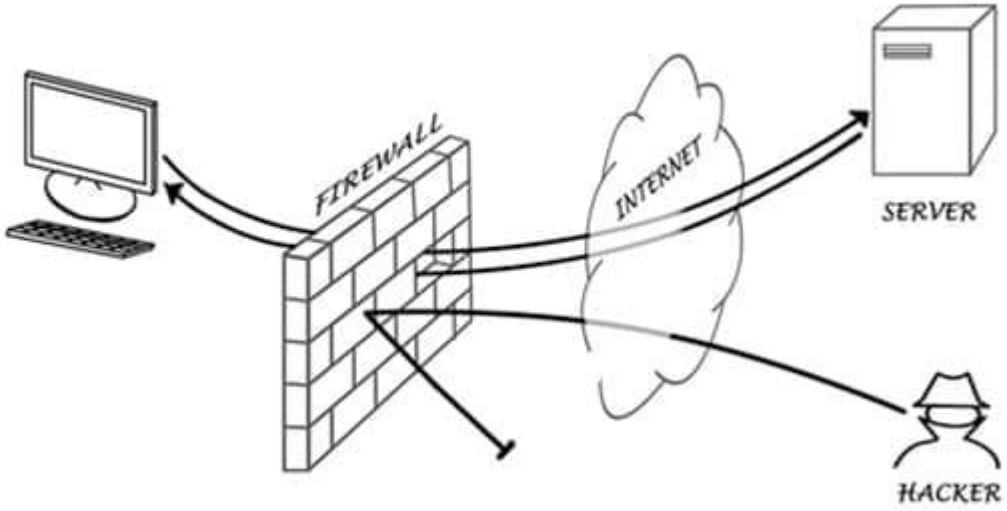
Asymmetric Encryption - Why we talk about PKI?



Firewall - Endpoint Protection

A firewall is a network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules.

The firewall **does not** protect from malware, spyware, SPAM, DDoS (distributed denial of service) attack.



Challenges:
Attack recognition
Re-Configuration

Types of firewalls - a reminder

1. **Software firewall** is installed on the host device. The advantage of it is that they can distinguish between programs while filtering incoming and outgoing traffic
2. **Hardware/dedicated firewall** is security devices that represent a separate piece of hardware placed between an internal and external network.
3. **Packet-filtering firewall** serves as an inline security checkpoint attached to a router or switch.
4. **Circuit-level gateway** ensures the established connections are safe.
5. **Stateful inspection firewall** keeps track of the state of a connection by monitoring the TCP 3-way handshake.
6. **Proxy firewall** protects a network by forwarding requests from the original client and masking it as its own.
7. **Next-generation firewall** checks the actual payload of the packet instead of focusing solely on header information.
8. **Cloud firewall or firewall-as-a-service (Faas)** is a cloud solution for network protection. It is maintained and run on the Internet by third-party vendors.
9. WAF (Web Application Firewall)

Intrusion Detection System

Challenges:
Attack recognition analysis
Prevention

Intrusion Detection System (IDS) is a system that monitors network traffic for suspicious activity and issues alerts when such activity is discovered.

IDS are classified into 5 types:

1. **Network Intrusion Detection System** are set up at a planned point within the network to examine traffic from all devices on the network.
2. **Host Intrusion Detection System** monitors the incoming and outgoing packets from the device only and will alert the administrator if suspicious or malicious activity is detected.
3. **Protocol-based Intrusion Detection System** comprises of a system or agent that would consistently resides at the front end of a server, controlling and interpreting the protocol between a user/device and the server.
4. **Application Protocol-based Intrusion Detection System** identifies the intrusions by monitoring and interpreting the communication on application specific protocols.
5. **Hybrid Intrusion Detection System**. In this system, host agent or system data is combined with network information to develop a complete view of the network system.

Intrusion Prevention System

Intrusion Prevention System is a network security application that monitors network or system activities for malicious activity. Major functions of intrusion prevention systems are to identify malicious activity, collect information about this activity, report it and attempt to block or stop it.

Intrusion Prevention System (IPS) is classified into 4 types:

1. **Network-based intrusion prevention system** monitors the entire network for suspicious traffic by analyzing protocol activity.
2. **Wireless intrusion prevention system** monitors a wireless network for suspicious traffic by analyzing wireless networking protocols.
3. **Network behavior analysis** examines network traffic to identify threats that generate unusual traffic flows, such as distributed denial of service attacks, specific forms of malware and policy violations.
4. **Host-based intrusion prevention system** is an inbuilt software package which operates a single host for doubtful activity by scanning events that occur within that host.

Malware Protection (blacklisting)

Blacklisting is one of the oldest algorithms in computer security, and it's used by most antivirus software to block unwanted entities.

The process of blacklisting applications involves the creation of a list containing all the applications or executables that might pose a threat to the network, either in the form of malware attacks or simply by hampering its state of productivity.

Keywords: Virus,Trojans, Malicious code, Kaspersky, F-Secure

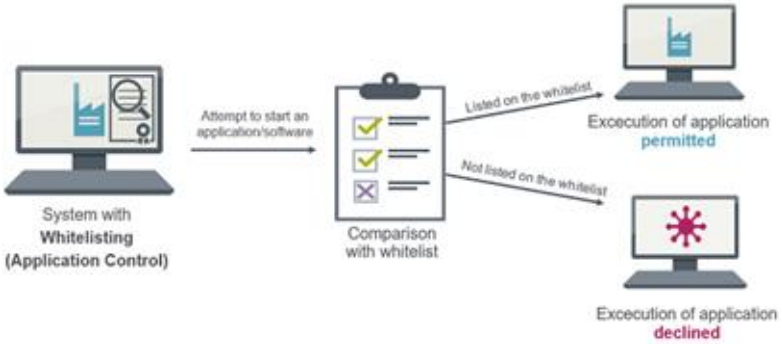




Malware Protection (whitelisting)

Whitelisting is the opposite of blacklisting, where a list of trusted entities such as applications and websites are created and exclusively allowed to function in the network.

This method of application control can either be based on policies like file name, product, and vendor, or it can be applied on an executable level, where the digital certificate or cryptographic hash of an executable is verified.

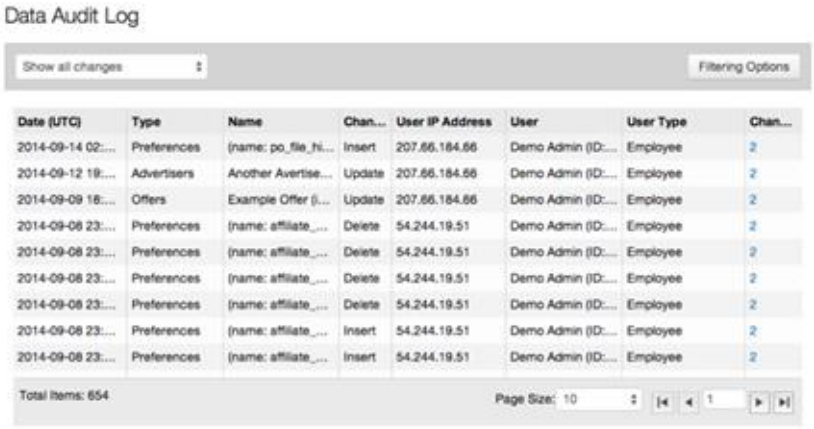


Keywords: Windows AppLocker, McAfee Embedded Control

Audit log

An audit log, also called an **audit trail**, is essentially a record of events and changes. IT devices across network create logs based on events. Audit logs are records of these event logs, typically regarding a sequence of activities or a specific activity.

Audit logs don’t always operate in the same way. But typically, they capture events by recording who performed an activity, what activity was performed, and how the system responded.



Patch Infrastructure & Processes

A **patch** is simply a piece of code that improves a program already installed into system — basically a bandage for computer software.



Patches can apply to nearly every infrastructure, including operating systems, desktops, routers, servers, office software and many other areas. **Patch management** allows to manage these patches better and keep infrastructure up-to-date and protected from threats.

Hardening Systems/Applications/Components

Use system functions to reduce the attack surface and improve the security situation.

With other words: If you have a lock, use the key to secure the door.

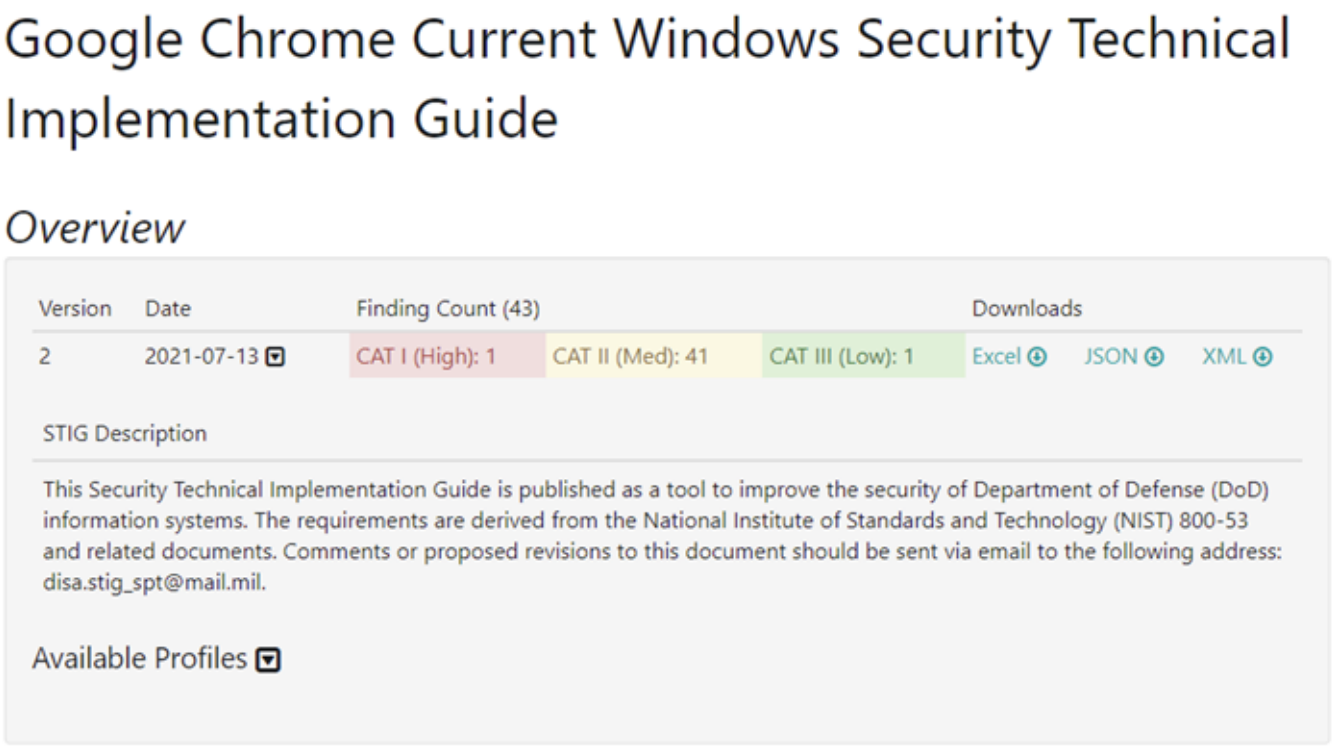
Hardening

STIG/SCAP based
https://public.cyber.mil/announcement/stig-update-october-2020-quarterly-release/

CIS Benchmark
https://www.cisecurity.org/cis-benchmarks/

Microsoft Security Compliance Toolkit 1.0 https://docs.microsoft.com/de-de/windows/security/threat-protection/security-compliance-toolkit-10

Security Technical Implementation Guide - STIG



Google Chrome Current Windows Security Technical Implementation Guide

Overview

Version	Date	Finding Count (43)			Downloads		
2	2021-07-13	CAT I (High): 1	CAT II (Med): 41	CAT III (Low): 1	Excel	JSON	XML

STIG Description

This Security Technical Implementation Guide is published as a tool to improve the security of Department of Defense (DoD) information systems. The requirements are derived from the National Institute of Standards and Technology (NIST) 800-53 and related documents. Comments or proposed revisions to this document should be sent via email to the following address: disa.stig_spt@mail.mil.

Available Profiles

STIG Example

Chrome must be configured to allow only TLS.

Overview

Finding ID	Version	Rule ID	IA Controls	Severity
V-234701	DTBC-0056	SV-234701r615937_rule		High

Description

If this policy is not configured then Google Chrome uses a default minimum version, which is TLS 1.0. Otherwise, it may be set to one of the following values: "tls1", "tls1.1" or "tls1.2". When set, Google Chrome will not use SSL/TLS versions less than the specified version. An unrecognized value will be ignored. "tls1" = TLS 1.0 "tls1.1" = TLS 1.1 "tls1.2" = TLS 1.2

STIG	Date
Google Chrome Current Windows Security Technical Implementation Guide	2021-07-13

Details

Check Text (C-37887r622475_chk)

Universal method:
1. In the omnibox (address bar) type chrome://policy
2. If "SSLVersionMin" is not displayed under the "Policy Name" column or it is not set to "tls1.2", this is a finding.
Windows method:
1. Start regedit
2. Navigate to HKLM\Software\Policies\Google\Chrome\
3. If the "SSLVersionMin" value name does not exist or its value data is not set to "tls1.2", this is a finding.

Fix Text (F-37849r622476_fix)

Windows group policy:
1. Open the "group policy editor" tool with gpedit.msc.
2. Navigate to Policy Path: Computer Configuration\Administrative Templates\Google\Google Chrome\
Policy Name: Minimum SSL version enabled
Policy State: Enabled
Policy Value: TLS 1.2

Contact

Chris Ditze-Stephan

https://www.linkedin.com/in/chris-ditze-stephan/

https://twitter.com/hintz2010

threema id: C43SFRTV

email: chris.ditze-stephan@zentric.com

Ende of Architecture & Design - Part I

Architecture & Design - Part II

ORGA

Multiple Choice Test am 21.12.2023

Es wird keine Aufzeichnung durchgeführt.

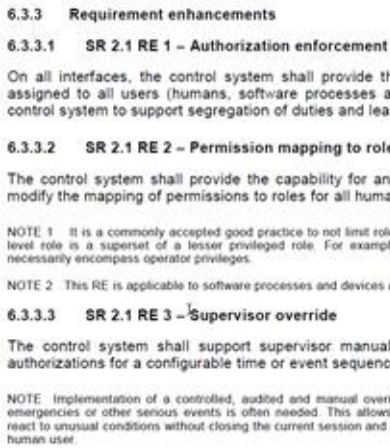
Fragen aus der Vorveranstaltung?

What is the challenge in a dedicated product like a diagnosis system or train controller?

First, do no harm!

GOAL

Fulfill relevant **security quality** attributes i**n the product's** ensure security controls are designed **properly** in detail.



6.3.3 Requirement enhancements

6.3.3.1 SR 2.1 RE 1 – Authorization enforcement

On all interfaces, the control system shall provide th assigned to all users (humans, software processes a control system to support segregation of duties and lea

6.3.3.2 SR 2.1 RE 2 – Permission mapping to role

The control system shall provide the capability for an modify the mapping of permissions to roles for all huma

NOTE 1 It is a commonly accepted good practice to not limit role level role is a superset of a lesser privileged role. For exampl necessarily encompass operator privileges.

NOTE 2 This RE is applicable to software processes and devices

6.3.3.3 SR 2.1 RE 3 – Supervisor override

The control system shall support supervisor manual authorizations for a configurable time or event sequenc

NOTE Implementation of a controlled, audited and manual overr emergencies or other serious events is often needed. This allows react to unusual conditions without closing the current session and human user.

Deliverables

1. Security quality attributes identified & prioritized, re **requirements derived**
2. (High-level security architecture defined/identified and documented (System decomposition, network topology, interfaces, security functionality))
3. Detailed **security design defined** and documented (Security Controls, Access Control, Hardening, Mitigations etc.)
4. Security **Zone & Conduits** for all Systems under Consideration (**SuC**) defined/identified

*ex. IEC 62443-3-1

Do’s

- follow an architecture design method - For example: IEC 62443 or NIST*
- discuss the architecture with all development participants
- define some principles which will simplify to follow them

Dont’s

- don’t over-detail the High-Level Security Architecture - more a schema

*OSA: http://www.opensecurityarchitecture.org/cms/19-foundations/foundations/1-open-security-architecture

System under Consideration (SuC)

This is already a prerequisite for a successful Risk Assessment.

Identify and list the “System under Consideration” (SuC).

The SuC consists of all infrastructure elements.

Database Server
Specific Cloud Service
Repositories
User Interfaces
Network Switch
etc

Security Zone

So it will be possible to assign Security Level to a Zone.

The zone is defined as the **logical or physical grouping** of industrial assets (which may be physical assets, applications or information) that **share the same security requirements**.

Conduit

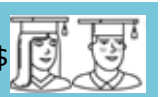
A Conduits is a zone applied to communication processes.
The Conduit provides security functions that enable two zones to communicate securely.
All communication between different zones must be carried out via a conduit.

Documentation of Zones

- name/unique identifier (z.B. C01´)
- logical and physical borders
- list of all points of access to and from the system (direction)
- list of data flows in access points (direction)
- connected zones and conduits inc. initiator
- list of associated assets
- external dependencies hypothesis
- target security levels
- current security levels
- applicable security policies (internal/ISO/NIST….)

Basic - Security Level

*FOSA Foreign State Actors

	Capability	Achieved	Target	
SL 4	Like SL 3 but with FOSA specific sophistic abilities and FOSA* high resource effort			$$$$ 
SL 3	Like SL 2 but with specific sophistic abilities and moderate resource effort			$$$ 
SL 2	Protects against intentional attacks with “monkey knowledge”			$$ 
SL 1	Protects against casual or accidental errors			$ 
SL 0	No Security required			

SL vector format

FORMAT → SL-?([FR,]domain) = { IAC UC SI DC RDF TRE RA }

SL-C(SIS Engineering Workstation) = { 3 3 2 3 0 0 1 }

SL-T(SIS Engineering Workstation) = { IAC:3/UC:3/SI:2/DC:3/RDF:0/TRE:0/RA:1 }*

SL-T = Target SL
SL-A = Achieved SL
SL-C = Capabilities SL

IAC - Identification and authentication control
UC - Use control
SI - System integrity
DC - Data confidentiality
RDF - Restricted data flow
TRE - Timely response to events
RA - Resource availability

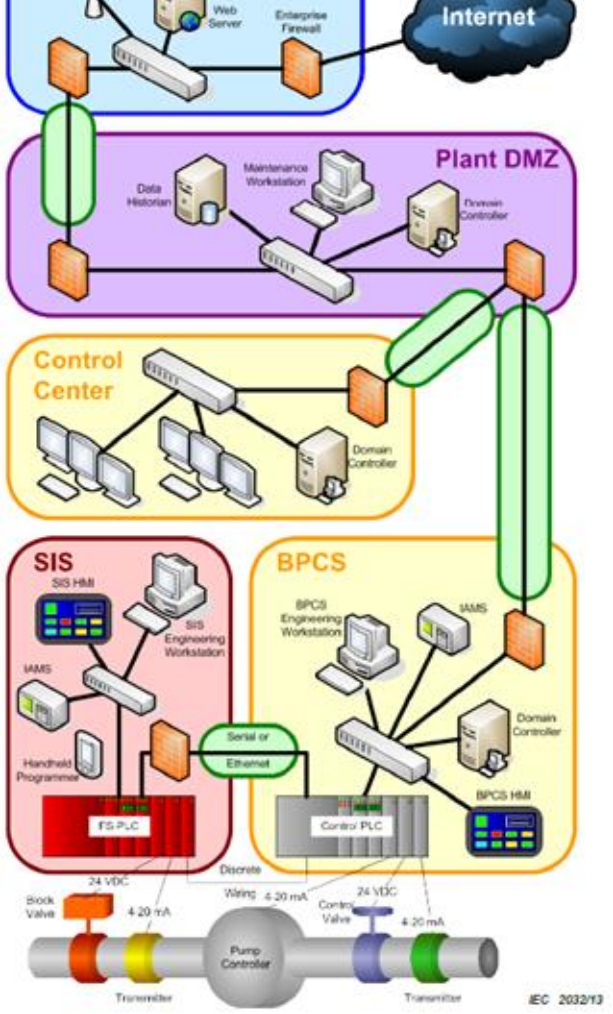
SL 0: No specific requirements or security protection necessary
SL 1: Protection against casual or coincidental violation
SL 2: Protection against intentional violation using simple means with low resources, generic skills and low motivation
SL 3: Protection against intentional violation using sophisticated means with moderate resources, IACS specific skills and moderate motivation
SL 4: Protection against intentional violation using sophisticated means with extended resources, IACS specific skills and high motivation

*Recommended for initial understanding.

SL to Requirement Level

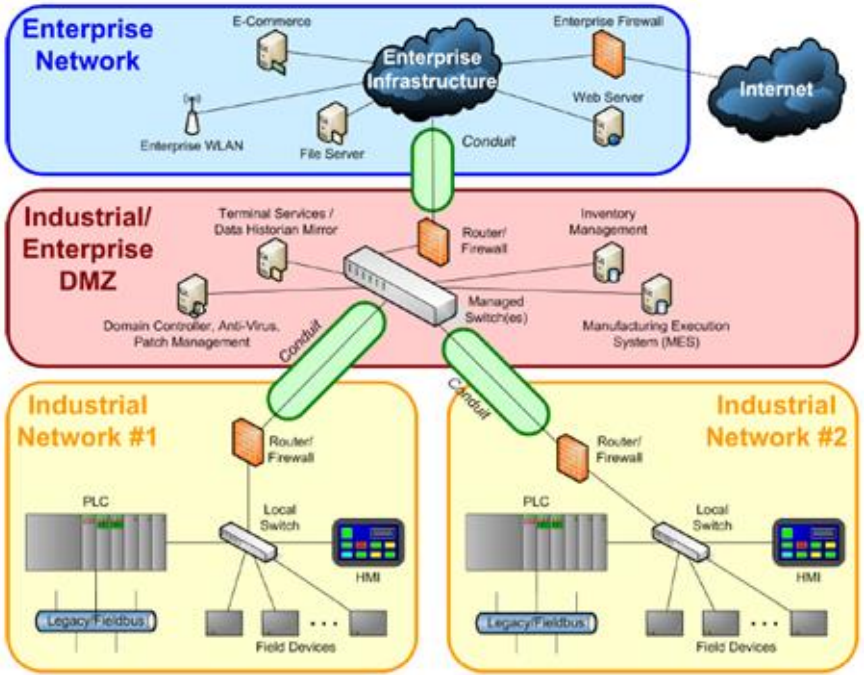
SRs and REs		SL 1	SL 2	SL 3	SL 4
FR 1 – Identification and authentication control (IAC)					
SR 1.1 – Human user identification and authentication	5.3	✓	✓	✓	✓
SR 1.1 RE 1 – Unique identification and authentication	5.3.3.1		✓	✓	✓
SR 1.1 RE 2 – Multifactor authentication for untrusted networks	5.3.3.2			✓	✓
SR 1.1 RE 3 – Multifactor authentication for all networks	5.3.3.3				✓
SR 1.2 – Software process and device identification and authentication	5.4		✓	✓	✓
SR 1.2 RE 1 – Unique identification and authentication	5.4.3.1			✓	✓
SR 1.3 – Account management	5.5	✓	✓	✓	✓
SR 1.3 RE 1 – Unified account management	5.5.3.1			✓	✓
SR 1.4 – Identifier management	5.6	✓	✓	✓	✓
SR 1.5 – Authenticator management	5.7	✓	✓	✓	✓
SR 1.5 RE 1 – Hardware security for software process identity credentials	5.7.3.1			✓	✓
SR 1.6 – Wireless access management	5.8	✓	✓	✓	✓
SR 1.6 RE 1 – Unique identification and authentication	5.8.3.1		✓	✓	✓
SR 1.7 – Strength of password-based authentication	5.9	✓	✓	✓	✓
SR 1.7 RE 1 – Password generation and lifetime restrictions for human users	5.9.3.1			✓	✓

High-level Manufacturing Exa



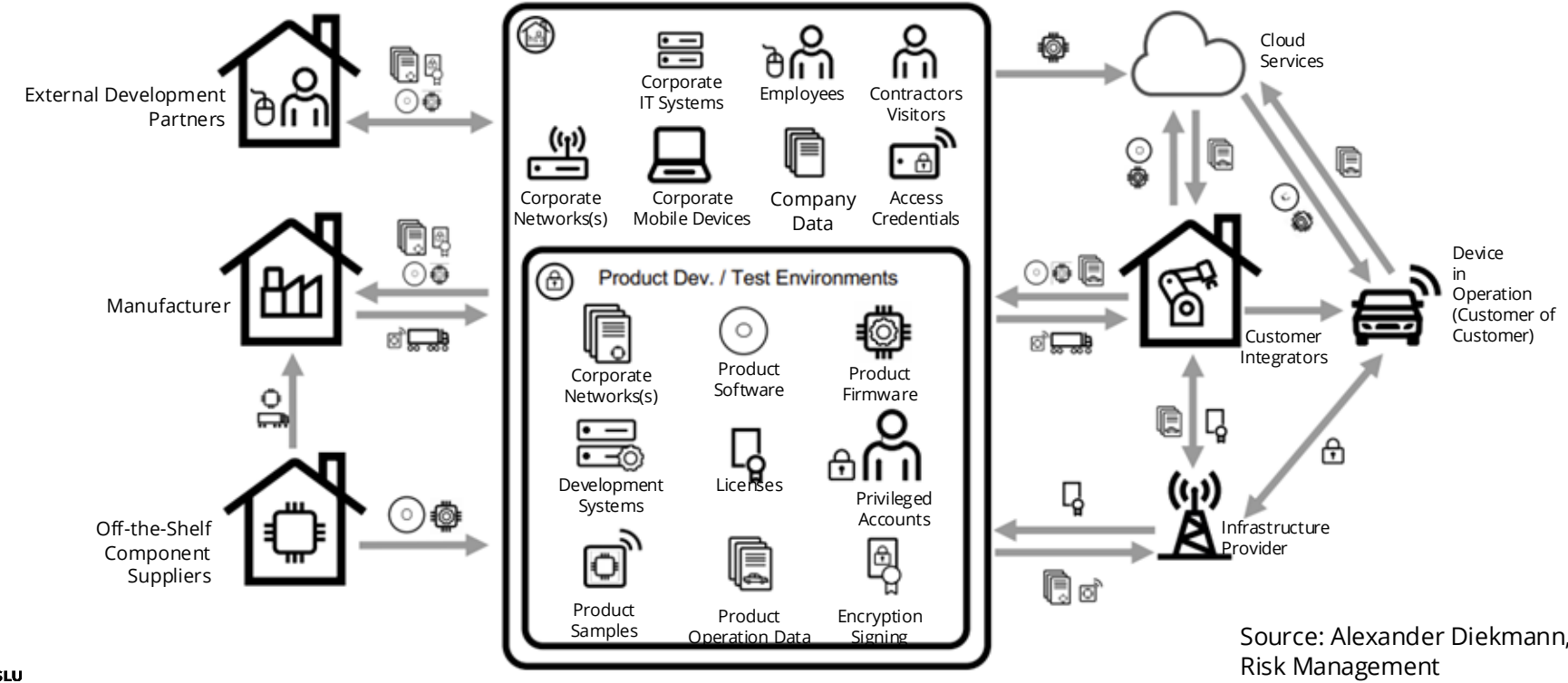
Source: IEC 62443-3-3 2013, Figure A.1

High-level Manufacturing Example 2



Source: IEC 62443-3-3 2013, Figure A.2

Example Data Flow Decomposition



Source: Alexander Diekmann, Risk Management

Measure Types

	Preventive	Detective	Retrospective
APPLICATION	Testing Awareness Training Firewall, Access Control Malware Protection	Vulnerability Monitoring	Remediation Incident Response Digital Forensic
NETWORK	IPS**/Threat Intelligence (SIEM*) Secure Web Gateways VPN-Encryption	Threat Intelligence (SIEM*) Intrusion Detection Traffic Analysis	Threat Intelligence (SIEM*) Remediation Incident Response Digital Forensic
ENDPOINT	Mobile Device Management Awareness Training Malware Protection Hardening	Intrusion Detection Malware Protection/Analysis Indicators of Compromise IoC Analysis	Remediation Incident Response Digital Forensic
CLOUD	Provide Toolchain Risk Management Encryption	Anomaly and Intrusion Analysis	Remediation Incident Response Digital Forensic

*SIEM Security Information and Event Management ** Intrusion Prevention

List of IEC 62443 based controls

SR 1.1 RE 1 – **Unique identification and authentication**
SR 1.1 RE 2 – Multifactor authentication for untrusted networks
SR 1.1 RE 3 – **Multifactor authentication for all networks**
SR 1.11 – Unsuccessful login attempts
SR 1.13 – Access via untrusted networks
SR 1.13 RE 1 – Explicit access request approval
SR 2.1 – Authorization enforcement
SR 2.1 RE 1 – **Authorization enforcement** for all users
SR 2.1 RE 2 – Permission mapping to roles
SR 2.1 RE 3 – Supervisor override
SR 2.1 RE 4 – Dual approval
SR 3.1 – Communication integrity
SR 3.1 RE 1 – Cryptographic integrity protection
SR 3.2 – **Malicious code protection**
SR 3.2 RE 1 – Malicious code protection on entry and exit points
SR 3.2 RE 2 – Central management and reporting for

SR 3.5 – **Input validation**
SR 4.3 – **Use of cryptography**
SR 5.1 – **Network segmentation**
SR 5.1 RE 1 – **Physical network segmentation**
SR 5.1 RE 2 – Independence from non-control system networks
SR 5.1 RE 3 – Logical and physical isolation of critical networks
SR 5.2 – Zone **boundary protection**
SR 5.2 RE 1 – Deny by default, allow by exception
SR 5.2 RE 2 – Island mode
SR 5.2 RE 3 – Fail close
SR 7.7 – **Least functionality**
SR 7.1 – **Denial of service protection**
SR 7.1 RE 1 – Manage communication loads
SR 7.1 RE 2 – Limit DoS effects to other systems or networks

Product Development and Defence in Depth or Zero Trust?

Several controls and mitigations like Firewall, Intrusion Prevention or Malware Protection can be useful, when a system itself provides vulnerabilities or weaknesses and can be exploited.

Finally the best way is to harden systems and services by configuration and avoid unneeded services, software and data.

Not only the one level has to protected. Defence in Depth is completed if we protect on every level of an infrastructure or system.

Hundreds of Meshed/Microservices connected via several security layers require specific independent security controls.

Exercice 1

Gruppenarbeit

Work in pre-defined breakout groups.

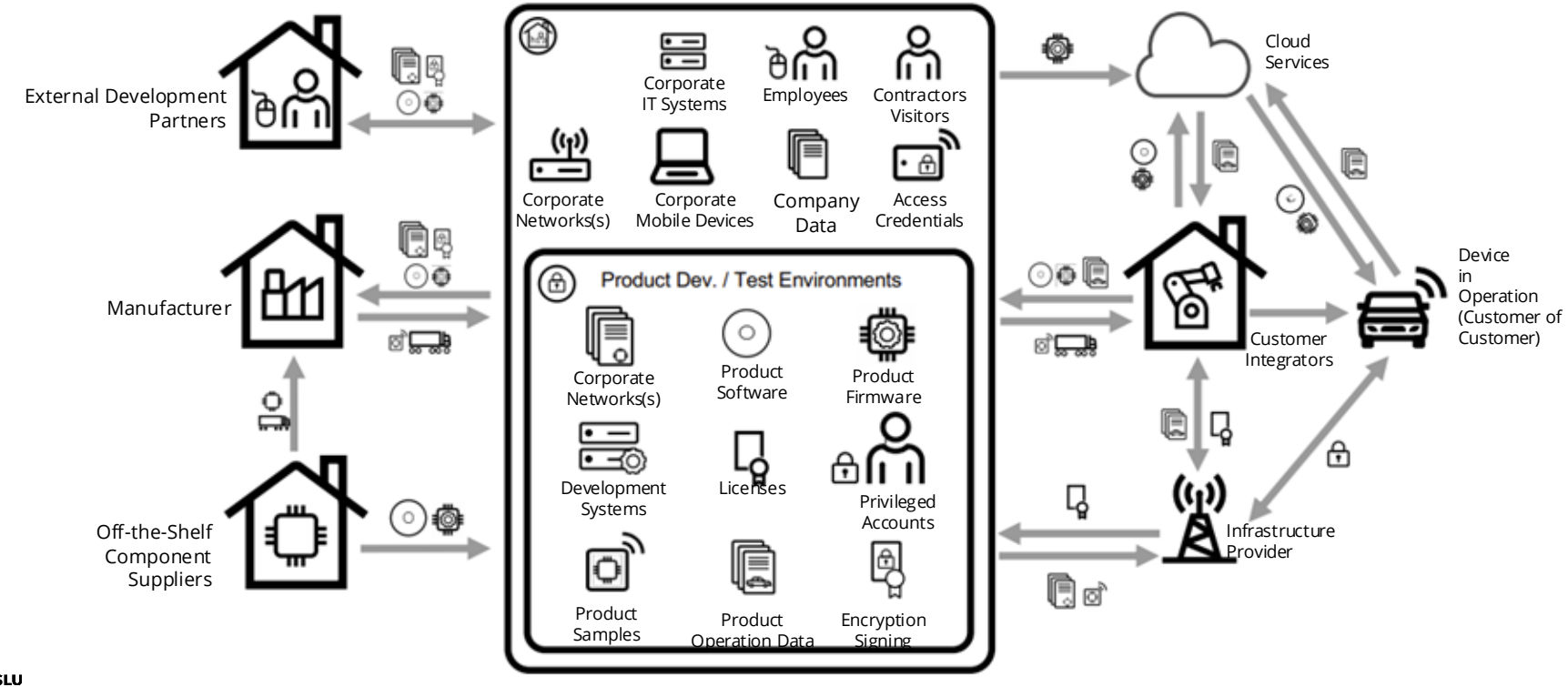
Estimated time effort: 30-40 min

Show results in the next exercise session per breakout room.

GOAL: Understanding the role of industrial standards like ISO/IEC 62443!

Example Data Flow Decomposition

Gruppenarbeit



Design Zones and Controls

Gruppenarbeit

1. Divide the given schema in senseful Security Zones (red, yellow, green)
2. Add given “Security Controls” to the defined several zone.

Sample

Zone: Yellow

Possible vector string: SL-T(Yellow Zone) =

{ IAC:3/UC:3/**SI:4**/DC:1/RDF:0/TRE:0/RA:1 }*

Controls:

SR 1.1 RE 1 (Unique identification and authentication),

SR 1.1 RE 2, (Multifactor authentication for untrusted networks),

…...

Requirements/Countermeasures 1

Gruppenarbeit

- SR 1.1 – Human user Identification and authentication (SL:1-4)
- SR 1.1 RE 1 – Unique identification and authentication (SL:2-4)
- SR 1.1 RE 2 – Multifactor authentication for untrusted networks (SL:3-4)
- SR 1.1 RE 3 – Multifactor authentication for all networks (SL:4)

SR 1.1 RE 3 = SR 1.1 (3)
If you require SL 4, all three requirements are mandatory.

IAC: Identification and authentication control

Requirements/Countermeasures 2

Gruppenarbeit

- SR 1.9 – Strength of public key authentication (SL:2-4)
- SR 1.9 RE 1 – Hardware security for public key authentication (SL:3-4)

IAC: Identification and authentication control

Requirements/Countermeasures 3

Gruppenarbeit

- SR 1.10 – Authenticator feedback (SL:1-4)
- SR 1.11 – Unsuccessful login attempts (SL:1-4)

IAC: Identification and authentication control

Requirements/Countermeasures 4

Gruppenarbeit

- SR 1.13 – Access via untrusted networks (SL:1-4)
- SR 1.13 RE 1 – Explicit access request approval (SL:3-4)

IAC: Identification and authentication control

Requirements/Countermeasures 5

Gruppenarbeit

- SR 2.1 – Authorization enforcement (SL:1-4)
- SR 2.1 RE 1 – Authorization enforcement for all users (SL:2-4)
- SR 2.1 RE 2 – Permission mapping to roles (SL:3-4)
- SR 2.1 RE 3 – Supervisor override (SL:3-4)
- SR 2.1 RE 4 – Dual approval (SL:4)

UC: Use control

Requirements/Countermeasures 6

Gruppenarbeit

- SR 3.1 – Communication integrity (SL:1-4)
- SR 3.1 RE 1 – Cryptographic integrity protection (SL:3-4)

SI: System Integrity

Requirements/Countermeasures 7

Gruppenarbeit

- SR 3.2 – Malicious code protection (SL:1-4)
- SR 3.2 RE 1 – Malicious code protection on entry and exit points (SL:2-4)
- SR 3.2 RE 2 – Central management and reporting for malicious code protection (SL:3-4)

Requirements/Countermeasures 8

Gruppenarbeit

SR 3.5 – Input validation (SL:1-4)

SI: System Integrity

Requirements/Countermeasures 9

Gruppenarbeit

SR 4.3 – Use of cryptography (SL:1-4)

DC: Data Confidentiality

Requirements/Countermeasures 10

Gruppenarbeit

- SR 5.1 – Network segmentation (SL:1-4)
- SR 5.1 RE 1 – Physical network segmentation (SL:2-4)
- SR 5.1 RE 2 – Independence from non-control system networks (SL:3-4)
- SR 5.1 RE 3 – Logical and physical isolation of critical networks (SL:4)

RDF: Restricted Data Flow

Requirements/Countermeasures 11

Gruppenarbeit

- SR 5.2 – Zone boundary protection (SL:1-4)
- SR 5.2 RE 1 – Deny by default, allow by exception (SL:2-4)
- SR 5.2 RE 2 – Island mode (SL:3-4)
- SR 5.2 RE 3 – Fail close (SL:3-4)

RDF: Restricted Data Flow

Requirements/Countermeasures 12

Gruppenarbeit

SR 7.7 – Least functionality (SL:1-4)

RA: Resource Availability

Requirements/Countermeasures 13

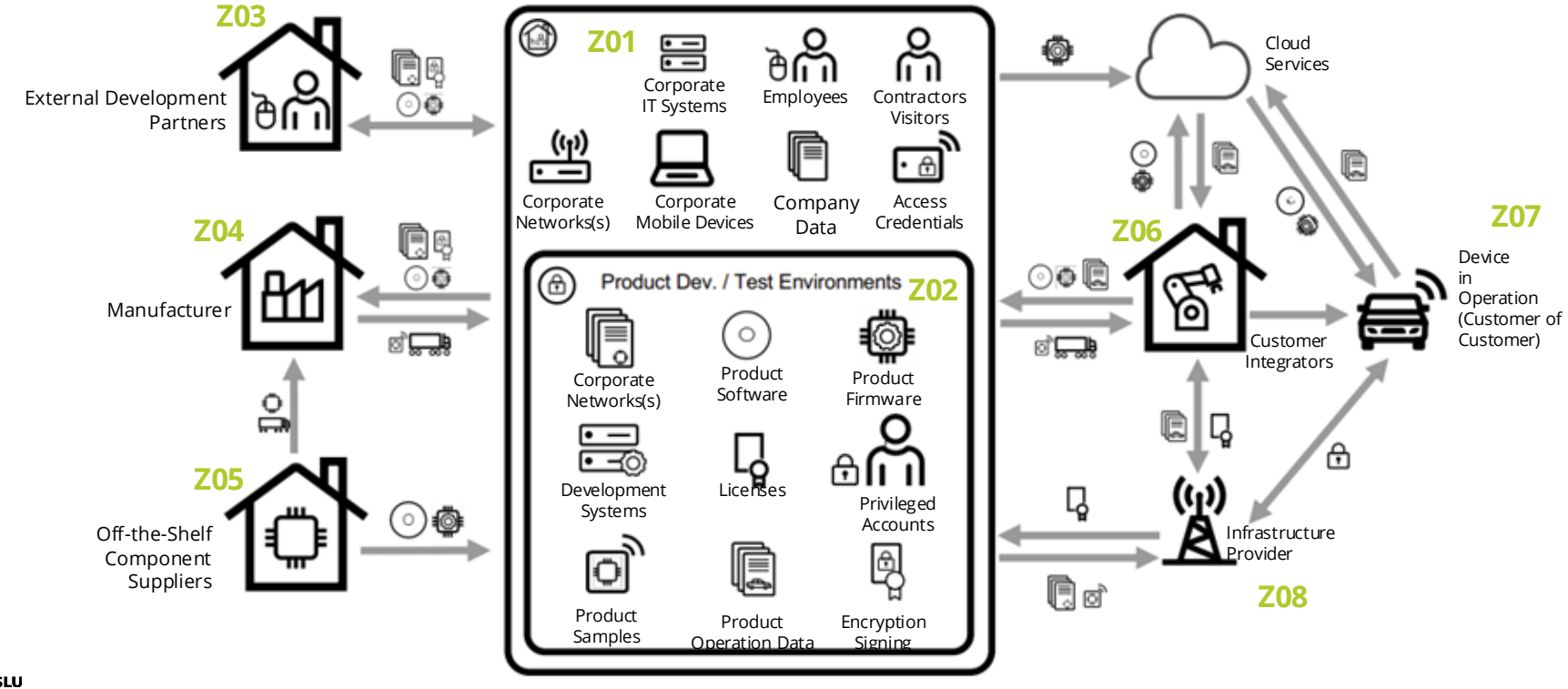
Gruppenarbeit

- SR 7.1 – Denial of service protection (SL:1-4)
- SR 7.1 RE 1 – Manage communication loads (SL:2-4)
- SR 7.1 RE 2 – Limit DoS effects to other systems or networks (SL:3-4)

RA: Resource Availability

Example Data Flow Decomposition

Gruppenarbeit



Contact

Chris Ditze-Stephan

https://www.linkedin.com/in/chris-ditze-stephan/

https://twitter.com/hintz2010

threema id: C43SFRTV

email: cds@zentric.com

Zum Multiple Choice Test

In Sachen Hausaufgabe zu den Themen der vergangenen Module habe ich folgendes vorgesehen:

1. Die Hausaufgabe wird als Multiple Choice Test absolviert.

3. Die vollständige Durchführung der Aufgabe wird kontrolliert und empfohlen.

5. Es wird bei dieser Hausaufgabe nur einen Durchführungsversuch geben.

6. Das Ergebnis dieses einen Versuch wird direkt bewertet und fließt in die Endnote ein.

7. In der Übungswoche stehe ich für Fragen und Diskussionen zur Verfügung.

8. Die Aufgaben sind ab xx 09:00 verfügbar und werden per E-Mail (url) auch noch mal versendet.